



Lab Title: Nmap Mastery and Vulnerability Mapping

Student Name: Nebeuwa Ifeanyichukwu Raphael

Student ID: 202520850LE

Course Name: BVWS102 - Web Application Security Essential

Instructor Name: AMMAR AMINU

Date of Submission: 4/1/2026

Executive Summary

This lab focused on developing practical skills in network reconnaissance and vulnerability mapping using Nmap. The primary objective was to identify active hosts, open ports, running services, and potential vulnerabilities within a controlled virtual lab environment. Two intentionally vulnerable targets - Metasploitable and OWASP Broken Web Applications (BWA) - were scanned from an attacker machine running Kali Linux.

Through various Nmap scanning techniques, including host discovery, service version detection, and vulnerability scanning using the Nmap Scripting Engine (NSE), critical security weaknesses such as outdated services, exposed network ports, and misconfigurations were identified. The results demonstrate how attackers can gather valuable intelligence during the reconnaissance phase and highlight the importance of proper system hardening and regular security assessments.

Lab Objective

The objectives of this lab were to:

- Configure a secure and isolated virtual lab environment using virtualization software.
- Identify active hosts and confirm network connectivity within the lab network.
- Perform and compare different Nmap scanning techniques, including aggressive and stealth scans.
- Enumerate open ports, services, and exact service versions running on target systems.
- Use the Nmap Scripting Engine (NSE) to identify common vulnerabilities and misconfigurations.
- Analyze scan results and translate technical findings into meaningful security insights.

Tools Used

The following tools and technologies were used during the lab:

- **VirtualBox / VMware** – For creating and managing the isolated virtual lab environment.
- **Kali Linux** – Attacker machine equipped with Nmap and other penetration testing tools.

- **Metasploitable 2/3** – Vulnerable target system for network service enumeration and vulnerability testing.
- **OWASP Broken Web Applications (BWA)** – Vulnerable web application platform for web-focused scanning.
- **Nmap (Network Mapper)** – Primary tool used for host discovery, port scanning, service enumeration, and vulnerability assessment using NSE scripts.

Methodology

The lab was conducted in a controlled virtual environment to ensure ethical and legal compliance. An attacker machine (Kali Linux) was connected to the same isolated network as the two target machines: Metasploitable and OWASP BWA.

The methodology followed a phased approach:

1. **Host Discovery and Reconnaissance**
A ping sweep was performed to identify live hosts within the network subnet. Once identified, basic and advanced scans were executed to compare aggressive and stealthy scanning techniques.
2. **Service Enumeration and Version Detection**
Service version detection scans were conducted to identify running services and their specific versions. Special focus was placed on network services on Metasploitable and web services on OWASP BWA.
3. **Vulnerability Assessment Using NSE**
Nmap NSE scripts were used to automate vulnerability detection, identify insecure configurations, and enumerate hidden web directories and applications.

All commands executed and their outputs were recorded and analyzed to support the findings and conclusions of the lab.

Lab Tasks and Deliverables

Phase 1: Host Discovery and Basic Reconnaissance

Goal: Confirm target reachability and compare the results of different scanning methodologies

Target Identification

```
TX errors 0  dropped 0  overruns 0  carrier 0  collisions 0

(raph@kali)-[~]
$ nmap -sn 192.168.146.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-02 12:08 EST
Nmap scan report for 192.168.146.1
Host is up (0.00076s latency).
MAC Address: 00:50:56:C0:00:08 (VMware)
Nmap scan report for 192.168.146.2
Host is up (0.00044s latency).
MAC Address: 00:50:56:E9:9C:8E (VMware)
Nmap scan report for 192.168.146.129
Host is up (0.0012s latency).
MAC Address: 00:0C:29:75:C5:8B (VMware)
Nmap scan report for 192.168.146.254
Host is up (0.0014s latency).
MAC Address: 00:50:56:EA:86:43 (VMware)
Nmap scan report for 192.168.146.128
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.38 seconds

(raph@kali)-[~]
$
```

Aggressive vs. Stealthy Scan Comparison (Target: Metasploitable)

Aggressive scanning

```

(raph@kali)-[~]
$ nmap -A 192.168.146.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-02 12:11 EST
Nmap scan report for 192.168.146.129
Host is up (0.0011s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 192.168.146.128
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_smtp_commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY,
|   ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ssl_v2:
|   SSLv2 supported
|   ciphers:

```

Stealthy SYN Scan

```
(raph@kali)-[~]
$ nmap -sS -T4 192.168.146.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-02 12:23 EST
Nmap scan report for 192.168.146.129
Host is up (0.0013s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:75:C5:8B (VMware)
```

Deliverable 1.1:

An aggressive scanning is designed for maximum information gathering in a single operation. It enables multiple advanced features simultaneously, including operating system detection, version detection and trace route. It is highly noisy, easily detected by firewalls and intrusion detection systems.

A stealthy SYN scan focuses on port discovery while minimizing visibility, Sends packet to initiate a connection and generates fewer logs on the target system compared to aggressive scanning.

Use Case: Stealthy SYN scan is preferred in the real world penetration testing where the avoiding detection is critical. It allows testers or attackers to map open ports without triggering alarms.

Phase 2: Detailed Service Enumeration and Version Detection

Goal: Precisely identify the services and their versions running on the targets to inform potential exploitation paths.

Comprehensive Service Versioning (Target: Metasploitable)

Service version scan against metasploitable IP

```

$ nmap -sV 192.168.146.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-02 12:33 EST
Nmap scan report for 192.168.146.129
Host is up (0.0013s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rexecd
513/tcp   open  login          to get started
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi        GNU Classpath grmiregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:75:C5:8B (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

```

Deliverable 2.1:

Port Name & Number	Port Version
FTP (Port 21)	Vsftpd 2.3.4
Samba (Ports 139 and 445)	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
SSH (Port 22)	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)

Web Service Focus (Target: OWASP BWA)

Service Version Scan specifically targeting the common web ports (80 and 443) on the OWASP BWA IP.

```
(raph@kali)-[~]
$ nmap -p 80,443 -sV 192.168.146.130
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-04 13:49 EST
Nmap scan report for 192.168.146.130
Host is up (0.0073s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.2.14 ((Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/Python/2.6.5 mod_ssl/2.2.14 OpenSSL ...)
443/tcp    open  ssl/http  Apache httpd 2.2.14 ((Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/Python/2.6.5 mod_ssl/2.2.14 OpenSSL ...)
MAC Address: 00:0C:29:61:F2:77 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.48 seconds
```

Deliverable 2.2:

Web server & Software	Port Version
Apache HTTP Server (Ubuntu)	Apache httpd 2.2.14

This information is crucial for a web application penetration test because identifying the web server software and its exact version allows the tester to understand the attack surface and focus on relevant, known vulnerabilities.

Phase 3: Vulnerability Scanning with the Nmap Scripting Engine (NSE)

Goal: Automate the detection of common vulnerabilities using Nmap's powerful scripting engine.

Network Vulnerability Check (Target: Metasploitable)

Executed a scan that runs the default scripts (-sC), performs service version detection (-sV), and runs the vulnerability category scripts (--script vuln) against the Metasploitable IP.

```
(raph@kali)-[~]
$ nmap -sC -sV --script vuln 192.168.146.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-04 12:24 EST
Nmap scan report for 192.168.146.129
Host is up (0.00060s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPD version 2.3.4 backdoor
|   State: VULNERABLE (Exploitable)
|   IDs:  CVE:CVE-2011-2523  BID:48539
|   vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|   Disclosure date: 2011-07-03
|   Exploit results:
|   Shell command: id
|   Results: uid=0(root) gid=0(root)
|   References:
|   https://www.securityfocus.com/bid/48539
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|   https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_2
|   http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|_ vulners:
|   vsftpd 2.3.4:
|   PACKETSTORM:162145      10.0      https://vulners.com/packetstorm/PACKETSTORM:162145      *EXPL
|   EDB-ID:49757      10.0      https://vulners.com/exploitdb/EDB-ID:49757      *EXPLOIT*
|   E9B0AEBB-5138-50BF-8922-2D87E3C046DD      10.0      https://vulners.com/githubexploit/E9B0AEBB-51
|   CVE-2011-2523      10.0      https://vulners.com/cve/CVE-2011-2523
|   CNVD-2020-46837      10.0      https://vulners.com/cnvd/CNVD-2020-46837
|   CC3F6C15-182F-53F6-A5CC-812D37F1F047      10.0      https://vulners.com/githubexploit/CC3F6C15-18
|   A41B5EAD-1A4C-56A6-97C6-1C58A1CF1E3B      10.0      https://vulners.com/githubexploit/A41B5EAD-1A
ouse pointer inside or press Ctrl+G.
```

Deliverable 3.1:

|_smb-vuln-ms10-061: false

|_smb-vuln-regsvcs-dos: ERROR: Script execution failed (use -d to debug)

|_smb-vuln-ms10-054: false

Web Application Enumeration (Target: OWASP BWA)

Executed a scan targeting port 80 on the OWASP BWA IP, specifically using the http-enum and http-title scripts.

```
(raph@kali)-[~]  
$ nmap -p 80 --script http-enum,http-title 192.168.146.130  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-04 14:04 EST  
Nmap scan report for 192.168.146.130  
Host is up (0.0011s latency).  
  
PORT      STATE SERVICE  
80/tcp    open  http  
|_ http-title: owaspbwa OWASP Broken Web Applications  
| http-enum:  
|   /wordpress/: Blog  
|   /test/: Test page  
|   /mono/: Mono  
|   /crossdomain.xml: Adobe Flash crossdomain policy  
|   /phpmyadmin/: phpMyAdmin  
|   /wordpress/wp-login.php: Wordpress login page.  
|   /cgi-bin/: Potentially interesting folder w/ directory listing  
|   /icons/: Potentially interesting folder w/ directory listing  
|_  /images/: Potentially interesting folder w/ directory listing  
MAC Address: 00:0C:29:61:F2:77 (VMware)  
  
Nmap done: 1 IP address (1 host up) scanned in 22.38 seconds
```

Deliverable:

- | /cgi-bin/: Potentially interesting folder w/ directory listing
- | /icons/: Potentially interesting folder w/ directory listing
- |_ /images/: Potentially interesting folder w/ directory listing

Based on my scan results, the NSE scripts revealed several serious security weaknesses on the target system. The presence of exposed services such as WordPress login pages, phpMyAdmin, and multiple directories with directory listing enabled significantly increases the attack surface. These misconfigurations could allow an attacker to perform brute-force attacks, gain unauthorized database access, or discover sensitive files and scripts. Overall, these findings indicate poor server hardening and make the web application highly vulnerable to exploitation, confirming that the system is insecure by design for testing purposes.

Conclusion

In this lab, I used Nmap to perform network reconnaissance and vulnerability mapping on Metasploitable and OWASP Broken Web Applications (BWA) in a controlled virtual environment. Through different scanning techniques such as aggressive scans, stealth SYN

scans, service version detection, and NSE scripts, I was able to identify running services, outdated software versions, and multiple security weaknesses. The results showed that both systems are highly vulnerable, with exposed services, poor configurations, and outdated applications. This lab helped me understand how Nmap is used in real penetration testing to discover security issues and assess the overall security posture of a target system.

Recommendation

Based on my findings, the following recommendations should be implemented to improve the security of the systems:

1. **Update and Patch Services**

All outdated services such as Apache, PHP, SSH, and other network services should be updated to the latest secure versions to reduce known vulnerabilities.

2. **Restrict Access to Sensitive Applications**

Applications like phpMyAdmin, WordPress login pages, and test directories should be restricted or removed from public access to prevent unauthorized use.

3. **Disable Directory Listing and Unused Services**

Directory listing should be disabled, and unnecessary services and folders should be removed to reduce the attack surface.

Overall, applying these security measures would significantly improve the security of both Metasploitable and OWASP BWA and help protect them against common attacks.